# Cyber Insurance Checklist

Cyber insurance is not a substitute for security controls. It is a financial backstop for when controls fail. This checklist helps you understand what you actually have, what you actually need, and what gaps to close before your next renewal.

## Before You Buy or Renew

- [ ] You have read the policy, not just the summary. Specifically the exclusions section.
- [ ] You understand the difference between first-party coverage (your own losses) and third-party coverage (claims made against you by others)
- [ ] Your broker has cybersecurity specialist expertise, not just general business insurance knowledge
- [ ] You have disclosed your actual security posture accurately on the application. Misrepresentation is the most common reason claims are denied.
- [ ] You know your policy's retroactive date (the earliest date from which a claim can arise)

## Coverage: What to Confirm Is Included

### Incident Response Costs

- [ ] Forensic investigation costs are covered
- [ ] Incident response firm engagement is covered
- [ ] The policy specifies which IR firms you are permitted to engage, and you have checked whether your preferred provider is on the panel

### Business Interruption

- [ ] Business interruption losses from a cyber incident are covered
- [ ] The waiting period (time before BI coverage kicks in) is defined and acceptable
- [ ] Coverage applies to dependent system failures (e.g. a cloud provider outage affecting your operations)

### Data Breach Costs

- [ ] Notification costs to affected individuals are covered
- [ ] Regulatory investigation costs and fines are covered (note: some policies exclude regulatory fines)
- [ ] Credit monitoring and identity protection services for affected individuals are covered
- [ ] Legal costs associated with a breach are covered

### Ransomware and Extortion

- [ ] Ransomware response and recovery costs are covered
- [ ] Ransom payments are covered (confirm this explicitly if it is a concern)
- [ ] Data recovery costs are covered
- [ ] The policy does not exclude ransomware attacks originating from nation-state actors or acts of war (this exclusion has been applied in disputed cases)

### Third-Party Liability

- [ ] Claims from clients whose data was compromised in your environment are covered
- [ ] Coverage applies to claims arising from failure to protect third-party data
- [ ] Media liability (e.g. defamation arising from digital content) is included if relevant

### Social Engineering and Funds Transfer Fraud

- [ ] Business email compromise and funds transfer fraud are covered
- [ ] The coverage limit for social engineering events is adequate for the transaction sizes in your business
- [ ] Coverage applies even when an employee authorised the transfer (most BEC losses involve authorised payments)

## Policy Conditions: What You Need in Place

Most cyber policies require certain security controls as a condition of coverage. Failure to maintain them can void a claim.

- [ ] Multi-factor authentication is enforced on all remote access and email (near-universal policy condition)
- [ ] MFA is enforced on all privileged accounts
- [ ] Endpoint detection and response (EDR) software is deployed across all endpoints
- [ ] Systems are patched within defined timeframes
- [ ] Offsite or immutable backups are maintained
- [ ] Staff receive regular security awareness training
- [ ] You have a documented incident response plan
- [ ] End-of-life or unsupported software is identified (some policies exclude incidents from unsupported systems)

## Limits and Sub-Limits: Things to Check

- [ ] The aggregate policy limit is sufficient to cover a realistic worst-case scenario for your business
- [ ] Sub-limits for ransomware payments, social engineering, and regulatory fines are adequate (these are often significantly lower than the main policy limit)
- [ ] The policy has a clear definition of a "cyber event" and you understand what falls inside and outside it
- [ ] The deductible (excess) is a number your business can absorb without material impact
- [ ] Coverage limits have been reviewed against your current revenue and data exposure, not just carried over from the previous year

## At the Time of an Incident

- [ ] You know your insurer's 24/7 incident notification number
- [ ] Your broker's emergency contact is saved somewhere accessible outside your primary systems (which may be offline during an incident)
- [ ] Your IR and legal team know to loop in the insurer before making public statements or paying a ransom
- [ ] You understand the documentation requirements for a claim and have a process for capturing evidence from the start of an incident
- [ ] You know your policy's notification timeframe (many policies require notification within 24 to 72 hours of discovering an incident)

## The Honest Reality About Cyber Insurance

Cyber insurance is valuable and you should have it. It is also frequently misunderstood as a solution to cyber risk rather than a financial instrument for managing residual risk.

Policies with weak security controls in place are increasingly being declined at renewal, written with significant exclusions, or subjected to much higher premiums.

> A current ASD Essentials assessment (the successor to the Essential Eight) and a managed detection and response service are the two most effective things you can do to improve your insurability and keep your premiums in check.

# Preparing for your next renewal?

Stealth Cyber works with Australian professional services firms on security posture assessments and managed protection. For independent advice on your cyber security position before your next insurance renewal, get in touch.


**WEBSITE**
stealthcyber.io

**EMAIL**
contact@stealthcyber.io

**PHONE (AU)**
+61 7 5230 8381

**PHONE (US)**
+1 (855) 774-2595

**OFFICES**
Gold Coast, AU | Sao Paulo, BR | Texas, US


© 2026 Stealth Cyber Pty Ltd. ABN 72 675 840 632. All rights reserved.